presents the token on each subsequent request, and the API can look up the token in a database on the server to see which user is associated with that session. When the user logs out, or the token expires, it is deleted from the database and the user must log in again if they want to keep using the API.

To switch to token-based authentication you'll introduce a dedicated new login endpoint. This endpoint could be a new route within an existing API or a brand-new API running as its own microservice. If your login requirements are more complicated, you might want to consider using an authentication service from an open-source or commercial vendor; but for now, you'll just hand-roll a simple solution using username and password authentication as before.

Token-based authentication is a little more complicated than the HTTP Basic authentication you have used so far, but the basic flow, shown in figure 4.4, is quite simple. Rather than send the username and password directly to the API endpoint, the client instead sends them to a dedicated login endpoint. The login endpoint verifies the username and password and then issues a time-limited token. The client then includes that token on subsequent API requests to authenticate. The API endpoint can authenticate the token because it is able to talk to a token store that is shared between the login endpoint and the API endpoint.